

SmartDocScan Security Overview

Application security posture summary.

APPLICATION SmartDocScan	DOCUMENT DATE June 25, 2026
GENERATED June 25, 2026	

Overview

SmartDocScan is a web application used to scan, store, retrieve, and manage medical document records. The current production architecture uses a React web frontend, .NET 8 API, Microsoft SQL Server database, file-based document storage, Docker containers, Caddy reverse proxy, and Dynamsoft Web TWAIN scanner integration.

Current public endpoints:

- Web application: `https://scan.ashunya.com`
 - API: `https://scanapi.ashunya.com`
 - Microsoft Entra redirect URI: `https://scanapi.ashunya.com/api/auth/microsoft/callback`
-

Authentication

SmartDocScan supports local username/password authentication and Microsoft Entra ID single sign-on using OpenID Connect.

Authentication uses secure server-side ASP.NET cookie sessions:

- Cookie name: `smartdocscan.session`
- `HttpOnly` enabled
- `Secure` required outside development
- `SameSite=Lax`
- Sliding expiration
- Server-side logout support

Authentication endpoints include rate limiting. Authentication activity is included in audit logging.

Authorization

SmartDocScan enforces company-level access boundaries in API operations. Users are associated with a company, and elevated access is controlled through explicit permission claims.

Permission areas include:

- Document upload
- Document scanning
- Document download
- Document deletion
- Document printing
- Category management
- User management
- Patient management
- Box/storage management
- Reporting
- Administrative access

Document preview and download operations require authentication and enforce tenant access checks.

Audit Logging

SmartDocScan records security-sensitive activity, including:

- Authentication success and failure
- Patient changes
- Document activity
- Settings updates
- Forbidden access attempts
- Administrative operations

Audit logs are available in the application to authorized administrators.

Audit log retention is configured through application security settings. The current default retention period is 365 days, with automated cleanup of audit records older than the configured retention window.

Transport Security

SmartDocScan is served over HTTPS. The production reverse proxy uses Caddy with public TLS certificates.

Live verification on June 25, 2026 showed:

- `https://scan.ashunya.com` responded over HTTPS.
- TLS 1.0 failed negotiation.
- TLS 1.1 failed negotiation.
- TLS 1.2 successfully negotiated.
- Security response headers were present on the public endpoint.

Security Headers

The production deployment sends browser and API hardening headers, including:

- `Content-Security-Policy`
- `Strict-Transport-Security`
- `X-Content-Type-Options: nosniff`
- `X-Frame-Options: DENY`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy`
- `Cross-Origin-Resource-Policy: same-site`
- `X-Permitted-Cross-Domain-Policies: none`
- `Cache-Control: no-cache, no-store, must-revalidate`
- `Pragma: no-cache`
- `Expires: 0`

The frontend Content Security Policy includes allowances required by Dynamsoft Web TWAIN scanning workflows, including scanner-service communication and browser behavior required by the scanner integration.

CORS And Cross-Site Request Protection

The API restricts browser CORS access to the configured frontend origin:

- `https://scan.ashunya.com`

Unsafe cross-site browser requests are rejected unless they come from an allowed origin or are part of the Microsoft SSO callback flow.

Data Storage

SmartDocScan stores metadata in Microsoft SQL Server and document files in a configured document storage path.

The production deployment separates application containers, SQL Server metadata storage, document file storage, TLS certificate data, and ASP.NET data protection keys.

The server drive that stores SmartDocScan data is protected with BitLocker drive encryption. The document data folder is restricted at the operating-system level so that access is limited to the application runtime and authorized administrative maintenance processes.

Backup And Recovery

The production environment uses a 3-2-1 backup strategy with air-gapped backup protection and immutable backup retention. This backup posture is designed to maintain multiple recoverable copies across separate storage locations and to protect backup sets from alteration or deletion during the immutability window.

Backup coverage includes database data, document storage, application configuration, TLS/certificate data, and ASP.NET data protection keys.

Endpoint Protection And Monitoring

The production server is secured with Sophos Managed Detection and Response. Sophos MDR provides managed endpoint monitoring, threat detection, investigation support, and response assistance for server-level security events.

External Components

SmartDocScan uses the following notable external components:

- Microsoft Entra ID for SSO
- Dynamsoft Web TWAIN for browser-based scanning
- Caddy for HTTPS reverse proxy and certificate automation
- StackHawk for dynamic application security testing
- Microsoft SQL Server for metadata storage
- Sophos MDR for server endpoint protection and managed detection/response

Dynamic Security Testing

Authenticated StackHawk DAST scanning was configured and run against the production API on June 25, 2026.

Scan target:

- `https://scanapi.ashunya.com`

Authentication method:

- SmartDocScan local login through `POST /api/auth/login`
- Server-side cookie authorization using `smartdocscan.session`
- Auth validation through `GET /api/auth/me`

The authenticated scan was expanded with a safe OpenAPI scan definition for authenticated API GET endpoints. Destructive production operations were excluded from active production scanning.

Observed scan result:

- Authentication succeeded.
- No critical findings were reported.
- No high findings were reported.
- No medium findings were reported.
- Low information-disclosure findings were reported for email-format values returned by authenticated JSON endpoints.

The low information-disclosure finding was reviewed in context. The affected responses are authenticated application responses and include user or record fields visible to authorized users.

Security Posture Summary

SmartDocScan currently includes:

- HTTPS transport with modern TLS
- Server-side authenticated sessions
- Microsoft Entra SSO support
- Tenant/company access checks
- Permission-based authorization
- Audit logging for security-sensitive activity
- 365-day default audit log retention
- BitLocker-encrypted server storage
- Operating-system restrictions around the document data folder
- Security response headers
- Restricted CORS configuration
- 3-2-1 air-gapped backup strategy with immutable retention
- Sophos MDR endpoint protection and managed detection/response
- Authenticated dynamic application security testing
- Controlled production scan scope for non-destructive testing

Statement

This document summarizes the current SmartDocScan application security posture and supporting technical controls as of June 25, 2026. Compliance posture for a healthcare deployment also depends on the operational environment, customer identity governance, backup procedures, retention policy, access review, incident response processes, and any applicable contractual or regulatory obligations.

This document summarizes application security controls and technical evidence as of the stated date.